

SMTP Guide: Wireshark Analysis of SMTP Traffic

What is SMTP?

SMTP (Simple Mail Transfer Protocol) is the standard protocol used for sending and relaying emails across the internet. It handles communication between email clients and servers, as well as between mail servers.

Like HTTP and FTP, **SMTP is plaintext by default**, making it very educational for packet analysis.

Typical Ports

- **TCP 25** — Standard SMTP (mail transfer)
- **TCP 587** — Submission (client to server, often with authentication)
- **TCP 465** — SMTPS (SMTP over SSL/TLS)

Why Analysts Care About SMTP

- Emails often contain sensitive information.
- Credentials can be sent in cleartext.
- SMTP is frequently abused for **spam**, **phishing**, and **malware delivery**.
- Email headers can reveal internal infrastructure and spoofing attempts.
- Valuable for forensics in business email compromise (BEC) and data exfiltration cases.

Wireshark Fundamentals for SMTP Analysis

1. Basic Filtering

Bash

```
smtp                # All SMTP traffic
tcp.port == 25      # Traditional SMTP port
smtp.command        # SMTP commands
smtp.response       # Server responses
smtp contains "MAIL FROM"
smtp contains "RCPT TO"
smtp contains "AUTH" # Authentication attempts
smtp contains "password"
```

2. Key SMTP Commands & Responses

Common Commands:

- HELO / EHLO — Greeting / Extended Hello
- MAIL FROM: — Sender address
- RCPT TO: — Recipient address
- DATA — Start sending email body

- AUTH — Authentication (LOGIN, PLAIN, CRAM-MD5, etc.)
- QUIT — End session
- RSET — Reset transaction

Common Server Responses:

- 220 — Service ready (includes banner)
- 250 — OK
- 235 — Authentication successful
- 334 — Authentication challenge (base64)
- 354 — Start mail input (after DATA)
- 550 — Mailbox unavailable / rejected

Email Structure in SMTP

1. Connection + Greeting
2. Authentication (if required)
3. Envelope: MAIL FROM and RCPT TO
4. Headers + Body (after DATA)
5. End with <CR><LF>.<CR><LF>

Common SMTP Analysis Scenarios in Thaghrach Challenges

1. **Credential Capture**
 - Extract usernames and passwords during AUTH LOGIN or AUTH PLAIN.
2. **Email Content Reconstruction**
 - Read full email (subject, body, attachments).
3. **Spoofed Sender Analysis**
 - Check if MAIL FROM differs from actual sender header.
4. **Phishing / Malware Delivery**
 - Analyze suspicious attachments or links.
5. **Base64 Decoding**
 - Many credentials and email parts are base64-encoded.
6. **Banner Grabbing**
 - Identify mail server software and version from 220 response.

Practical Workflow in Wireshark

1. Filter smtp or tcp.port == 25.
2. **Follow** → **TCP Stream** on the SMTP conversation — this gives you the cleanest view.
3. Look for AUTH LOGIN — the next two lines are usually base64 username and password.
4. Go to the DATA command and read the full email that follows.
5. Use **Export Objects** → **SMTP** (if available) or manually copy the body.
6. Decode base64 strings using CyberChef or Wireshark's built-in tools.

Handy Trick: Right-click → **Decode As** → SMTP if Wireshark doesn't auto-detect it.

Security Red Flags in SMTP Traffic

- Plaintext authentication (AUTH LOGIN or AUTH PLAIN).
- Suspicious MAIL FROM addresses (spoofing).
- Emails with suspicious subjects or attachments.
- Large base64 blobs in the body (possible malware).
- Internal mail servers talking to external IPs.

Example Challenge Goals You Will Encounter

- Extract the username and password used to send the email.
 - Read the full secret message sent via email.
 - Find the flag hidden in the email body or an attachment.
 - Identify signs of email spoofing.
 - Reconstruct an entire phishing email from the SMTP session.
-

Tips for Thaghras Students:

- Always use **Follow TCP Stream** — SMTP is much easier to read this way.
- Base64-decode any AUTH credentials immediately.
- Pay attention to both the SMTP envelope (MAIL FROM/RCPT TO) and the actual email headers.
- Look for the flag in the message body, subject, or attachments.